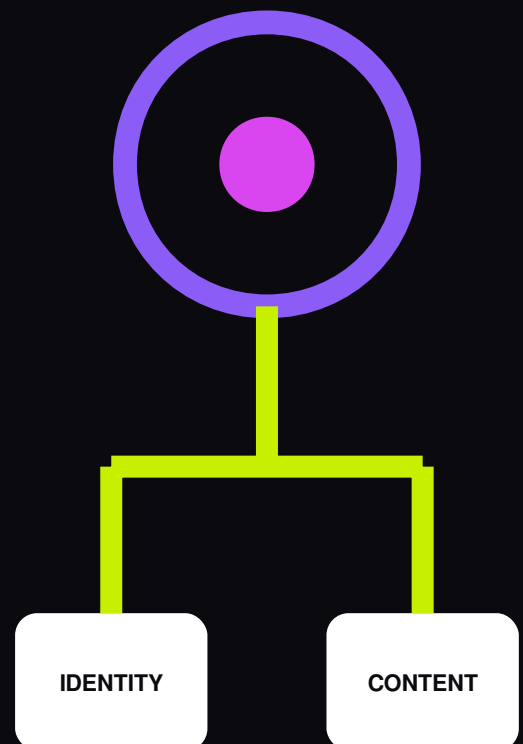


ACTOR-CONTROLLED MFA METHOD ADDITION

Hunts a successful identity update in which the number of MFA device records increases between the published old and new authentication-method snapshots.

HUNTING QUERY

CONFIDENCE: MEDIUM



EVIDENCE BEFORE ALERTING

REPORT DATE

14 September 2026

STATUS

Untested implementation sketch

PRIMARY PLATFORM

Microsoft Defender XDR

OPERATIONAL VALUE

9.7 / 10



EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

9.7

Hunts a successful identity update in which the number of MFA device records increases between the published old and new authentication-method snapshots.

STATUS

Hunting query

Untested implementation sketch; Confidence Medium.

1primary table

0joins

0secondary rules

2validation gates

Evidence boundary

A result proves only that an MFA device record was added. It does not prove actor ownership, phishing, token theft, later use, persistence survival, or data access.



BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

Source-supported fact

- 1 Microsoft observed actors register a phone, authenticator application, or software OTP token under their control after initial access.
- 2 A redacted 4 September 2026 event shows Update user., Success, and an added StrongAuthenticationPhoneAppDetail entry.
- 3 Microsoft published the OldValue/NewValue device-count comparison used by this hunt.

Detection hypothesis

If an attacker repeats this behavior, CloudAppEvents should expose the same source-supported identity or content-access pattern. Distinction requires ownership, change, device, sign-in, and approved-automation context.

Unconfirmed elements

A result proves only that an MFA device record was added. It does not prove actor ownership, phishing, token theft, later use, persistence survival, or data access.

Logic: Behavioral **ATT&CK:** T1098.005



TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

Microsoft Defender for Cloud Apps must populate CloudAppEvents with Microsoft 365 activities and complete RawEventData.ModifiedProperties.

OPTIONAL ENRICHMENT

Entra sign-in risk, authentication protocol, device compliance, IP context, user confirmation, IAM/helpdesk change record, and subsequent Graph activity.

Fields	Reliability	Use
Timestamp, ActionType, RawEventData	Documented	Query or triage
AccountId, AccountDisplayName	Documented	Query or triage
IPAddress, Application, ReportId	Documented	Query or triage
ResultStatus, Target, ModifiedProperties	Present in source	Query or triage
Name, OldValue, NewValue	Present in source	Query or triage

Excluded

No message body, phishing-page content, inferred success, actor attribution, or undocumented cross-SIEM mapping is used.



PRIMARY KQL

Direct source-supported conditions with investigable output.

HUNTING

STATUS

Hunting query — Untested implementation sketch

KQL — UNTESTED

```
CloudAppEvents
| where ActionType == "Update user."
| where toString(RawEventData.ResultStatus) == "Success"
| where RawEventData has_any
    ("StrongAuthenticationPhoneAppDetail",
    "StrongAuthenticationUserDetails")
| extend AccountObjectId = extract(
    @"User_{[a-f0-9\-\+]}", 1,
    toString(RawEventData.Target))
| where isnotempty(AccountObjectId)
| mv-expand ModifiedProp = RawEventData.ModifiedProperties
| where toString(ModifiedProp.Name) in
    ("StrongAuthenticationPhoneAppDetail",
    "StrongAuthenticationUserDetails")
| extend OldValue = toString(ModifiedProp.OldValue),
    NewValue = toString(ModifiedProp.NewValue)
| extend OldDeviceCount = countof(OldValue, @"""Id"""),
    NewDeviceCount = countof(NewValue, @"""Id""")
| where NewDeviceCount > OldDeviceCount
| project Timestamp, AccountObjectId, AccountId,
    AccountDisplayName, IPAddress, Application, ActionType,
    OldDeviceCount, NewDeviceCount, OldValue, NewValue, ReportId
| order by Timestamp desc
```

WINDOW

None

THRESHOLD

Old/new delta

JOIN

None

EXPANSION

ModifiedProperties



TRIAGE AND TUNING

Human validation before response.

WORKFLOW

1

Preserve

Retain raw event, account, IP, timestamps, and report identifiers.

2

Confirm

Identify the user, change record, service owner, and device context.

3

Enrich

Entra sign-in risk, authentication protocol, device compliance, IP context, user confirmation, IAM/helpdesk change record, and subsequent Graph activity.

4

Scope

Review adjacent identity, Graph, SharePoint, OneDrive, and Exchange evidence.

Expected benign overlap

Legitimate enrollment, device replacement, recovery, onboarding, MFA reset, Authenticator migration, delegated administration, and identity automation. Confirm ownership and change records before response.

Response boundary

A result proves only that an MFA device record was added. It does not prove actor ownership, phishing, token theft, later use, persistence survival, or data access.



VALIDATION GATES

Controlled tests and cross-SIEM limits.

QUALITY CONTROL

Validation steps

- 1. Generate a controlled MFA enrollment and preserve the raw event.
- 2. Verify both property names and the User_<GUID> target representation.
- 3. Compare 30 days of results with IAM and helpdesk changes.
- 4. Confirm every result retains identity, IP, and raw old/new values.

Decision criteria

Success: Controlled enrollment produces NewDeviceCount > OldDeviceCount and the benign set is attributable.

Rejection: The count does not stably represent new devices or benign overlap cannot be separated.

Failure: CloudAppEvents, nested properties, or raw old/new values are unavailable.

Platform	Decision	Missing evidence
Defender XDR	Hunting query	Target execution and baseline
Splunk	No reliable implementation	Index, sourcetype, parser, sample
Chronicle	No reliable implementation	Parser and exact UDM mapping



CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

Hunting query

Hunts a successful identity update in which the number of MFA device records increases between the published old and new authentication-method snapshots.

A result proves only that an MFA device record was added. It does not prove actor ownership, phishing, token theft, later use, persistence survival, or data access.

MITRE ATT&CK

T1098.005

References

1. Microsoft Security Research — Passkey-themed social engineering leads to identity and cloud compromise — 09 Sep 2026
2. Microsoft Learn — CloudAppEvents advanced hunting schema — accessed 14 Sep 2026
3. MITRE ATT&CK — T1098.005

Document control

English dossier. No customer data. URLs are defanged in references.txt. HTML and rendering assets remain private.